Table des matières

Profils utilisateurs - moyun-pos 1
1. Correspondance des profils 1
2. Capacités par profil 1
3. Mécanismes d'enforcement 2
4. Journal des accès 2
5. Politique de mots de passe 2
6. Limitations connues 3

Profils utilisateurs - moyun-pos

Le Manuel de certification SCE 2.0 (Introduction, p.9) impose trois profils d'accès distincts au système :

- Gérant / Technicien ("Manager / Technicien")
- Serveur
- Apprenti

Le présent document établit la correspondance entre ces profils attendus par le SPF Finances et les rôles techniques implémentés dans `crates/pos-core/src/user.rs`.

1. Correspondance des profils

Profil SCE 2.0	Rôle technique `moyun-pos`	Code source
Gérant / Technicien	`UserRole::Admin`	`crates/pos-core/src/user.rs:6`
Serveur	`UserRole::Cashier`	`crates/pos-core/src/user.rs:7`
Apprenti	`UserRole::Waiter`	`crates/pos-core/src/user.rs:8`

Chaque utilisateur du POS est stocké dans la table `users` (`crates/pos-db/src/schema.rs`) avec : - son numéro INSZ à 11 chiffres (clé primaire, validé par `validate_insz` dans `crates/pos-core/src/user.rs:46`) ; - son rôle (`admin` / `cashier` / `waiter`) ; - un hash bcrypt de son code PIN (facultatif) ; - un drapeau `active` pour désactiver un utilisateur sans le supprimer (la suppression n'est autorisée que pour les utilisateurs n'ayant jamais effectué d'événement fiscal - voir §III.C).

2. Capacités par profil

2.1 Gérant / Technicien (**`Admin`**)

Accès complet. Concrètement, peut :

- Effectuer toutes les opérations d'un Serveur (ci-dessous).
- Générer un rapport X (à tout moment de la journée).
- Générer un rapport Z (clôture de journée fiscale).
- Saisir un Money-in / Money-out (Événement F - fonds de caisse, pourboires, retrait).
- Ouvrir le tiroir-caisse hors-vente (Événement F-WAR - drawer-open).
- Émettre une copie de ticket (Événement C).
- Effectuer un remboursement complet (Événement N, M111) ou partiel (M112B - événement séparé, voir `REFUND_FLOW.md`).
- Activer / désactiver le mode formation (Événements T).
- Accéder à la vue Paramètres (`SettingsView.vue`) : configuration du restaurant, période de réservation, etc.
- Créer / désactiver des utilisateurs.

2.2 Serveur (**`Cashier`**)

Profil d'opérateur de caisse standard. Peut :

- Se connecter avec INSZ + code PIN (Événement S - `signWorkIn`).
- Se déconnecter (Événement S - `signWorkOut`).
- Ouvrir / réutiliser une table en cours.
- Ajouter, retirer ou modifier les lignes d'une commande ouverte.
- Envoyer la commande en cuisine (Événement P - `signOrder`).
- Imprimer un pré-ticket (Événement P - `signPreBill`).
- Encaisser : encaissement comptant ou carte (Événement N - `signSale`). Tiroir s'ouvre automatiquement pour les paiements comptant.
- Consulter les commandes ouvertes et fermées de sa session.

2.3 Apprenti (**`Waiter`**)

Profil restreint. Peut :

- Se connecter / se déconnecter.
- Ouvrir / réutiliser une table.
- Ajouter des lignes à une commande.
- Envoyer la commande en cuisine.
- NE peut PAS encaisser. Une tentative d'encaissement renvoie un message demandant l'intervention d'un Serveur ou d'un Gérant.
- NE peut PAS générer de rapport, copier un ticket, rembourser, ouvrir le tiroir, ni modifier les paramètres.

3. Mécanismes d'enforcement

L'enforcement vit à deux niveaux :

1. Niveau UI (`ui/src/stores/auth.ts` et chaque vue Vue) - les boutons et écrans réservés à un rôle supérieur sont cachés à l'apprenti. Cette couche est purement ergonomique.
2. Niveau commande Tauri (couche autoritative). Chaque `#[tauri::command]` qui mute un événement fiscal vérifie le rôle de l'opérateur via le champ `users.role` correspondant à l'INSZ passé en paramètre. Une tentative non autorisée renvoie `Err("Forbidden")` sans toucher au compteur ni à la base.

L'enforcement applicatif est doublé par la conception fiscale : - l'INSZ qui apparaît dans le champ `userInsz` de chaque `*Input` est celui de l'opérateur connecté ; - toute discordance entre la session UI et l'INSZ envoyé au FDM est refusée par la couche `auth` avant émission de la mutation.

4. Journal des accès

Chaque connexion (Événement S - `signWorkIn`) et chaque déconnexion (Événement S - `signWorkOut`) est consignée dans la table `fiscal_events` avec : - `event_type = 'S'` - `user_insz` = INSZ de l'opérateur - `created_at` = horodatage de l'événement - `fdm_response_json` = réponse signée du FDM

Ces lignes constituent le journal Dimona-compatible exigible par l'ONSS et utilisable pour reconstruire intégralement les heures de présence du personnel.

5. Politique de mots de passe

- Les PINs sont stockés sous forme de hash bcrypt (coût 12) dans la colonne `users.pin_hash`. Le PIN lui-même n'est jamais stocké en clair ni journalisé.
- Un PIN n'est pas obligatoire : un utilisateur sans PIN peut se connecter uniquement par INSZ - utile pour les apprentis en période d'essai. Le drapeau `has_pin` (calculé) informe le frontend de présenter ou non le pavé numérique de PIN.

— En l'absence de PIN, la sécurité repose sur l'unicité physique du poste (terminal à l'entrée du restaurant, kiosk-mode plein écran).

6. Limitations connues

— Le rôle Apprenti n'est pas encore exposé dans l'interface de création d'utilisateur (`SettingsView.vue`). Pour le moment seuls Admin et Cashier sont créables via l'UI ; un Apprenti doit être inséré via la table `users` directement (`PROGRAMMING_MANUAL_FR.md` §3). À corriger avant déploiement.
— Pas de gestion multi-niveau pour Gérant vs Technicien : les deux utilisent `UserRole::Admin`. Le manuel SCE 2.0 ne distingue pas formellement les deux dans la matrice de capacités ; les deux profils ont accès complet.